

Privacy Proxy OSS Readiness

Current checklist for publishing the Gateway.fm Privacy Proxy source repository under Apache-2.0. Source release is tracked separately from official binary and container image releases.

Snapshot: July 7, 2026 Branch: oss/source-only-apache2-readiness Scope: source-only Apache-2.0

Download PDF Download standalone HTML

CloseSource-only Apache-2.0 publication is within reach after final coordination items.

5Critical source-public items remain before making the repository public.

HoldDo not publish official binaries or Docker images yet.

4Gateway repositories belong in the coordinated Apache plan.

Verdict

Source-only Apache-2.0 publication is close, but the coordinated Gateway repositories and public workflow posture still need final handling. Official binaries/images should wait for SBOMs, provenance, notices, and LGPL binary-distribution review.

Done On The OSS Readiness Branch

- | Status | Item
- | Done | Added root Apache-2.0 LICENSE.
- | Done | Changed README license section from MIT to Apache-2.0.
- | Done | Added license: Apache-2.0 to npm manifests and lockfile root metadata.
- | Done | Added starter NOTICE and THIRD_PARTY_NOTICES.md.
- | Done | Added SECURITY.md, CONTRIBUTING.md, CODE_OF_CONDUCT.md, and GOVERNANCE.md.
- | Done | Ignored internal audit report filenames so they are not accidentally committed.
- | Done | Switched tools/wallet-emulator-js submodule URL from SSH to public HTTPS.
- | Done | Aligned project-owned Solidity SPDX identifiers with Apache-2.0.
- | Done | Removed the accidental .agents gitlink on the base hygiene branch.

Must Finish Before Making The Source Repo Public

- | Priority | Item | Why it matters
- | Critical | Confirm legal copyright holder text for NOTICE. | The public notice needs the correct legal owner.
- | Critical | Confirm the private vulnerability contact in SECURITY.md. | The public repo needs a working private disclosure path.

| Critical | Publish or coordinate gateway-fm/chain-indexer under Apache-2.0. | Privacy Proxy references chain-indexer proto/generated code and privacy-mode deployment depends on it.

| Critical | Publish or coordinate gateway-fm/block-explorer under Apache-2.0. | Privacy-mode docs and compose workflows depend on this sibling repo.

| Critical | Decide whether gateway-fm/wallet-emulator-js is public Apache-2.0; otherwise remove or replace it. | A public source repo should not point at a private or unclearly licensed submodule.

| High | Make .github/workflows/privacy-bypass.yml safe for public forks without CROSS_REPO_READ_TOKEN, or disable it for public PRs until sibling repos are public. | Public contributors should not hit broken/private cross-repo checkout behavior.

| High | Scrub public docs for private Linear URLs and internal roadmap wording. | Public docs should not expose internal planning systems or confusing private context.

| Medium | Decide whether to keep RD-XXXX references outside migrations or strip them. | They are not secrets, but they are noisy internal tracking artifacts.

| Medium | Decide whether to keep .mcp.json tracked publicly or move it to an example file. | The file is not secret, but it auto-configures a local MCP command.

| Medium | Decide git-history email posture. | Accept as normal OSS attribution or rewrite before public launch.

| Medium | Confirm inbound contribution policy enforcement. | DCO is documented; CI enforcement is a maintainer decision.

Prompts To Run Next

Use these prompts as task briefs. Each prompt should produce either a focused PR or a written decision record.

Legal notice, security contact, and inbound policy

Take the current OSS readiness branch for gateway-fm/privacy-proxy. Verify the public source-only Apache-2.0 legal artifacts: LICENSE, NOTICE, SECURITY.md, CONTRIBUTING.md, CODE_OF_CONDUCT.md, GOVERNANCE.md, README license text, and package metadata. Confirm the correct copyright holder, security contact, and inbound contribution posture. Make only minimal public-source-readiness edits and list any remaining legal decisions that require counsel.

Gateway sibling repositories

Audit gateway-fm/chain-indexer and gateway-fm/block-explorer for source-only Apache-2.0 publication readiness. Check LICENSE, NOTICE, README license text, package metadata, third-party notices, generated code provenance, secrets, private links, CI behavior for public forks, and image/binary release blockers. Produce a short blocker list and minimal PR-ready fixes.

Wallet emulator submodule decision

Determine whether gateway-fm/wallet-emulator-js can be made public under an

Apache-compatible license before privacy-proxy is public. If yes, prepare the minimum license/notice/metadata changes in that repo. If no, prepare a privacy-proxy PR that removes or replaces the submodule and updates docs/tests that refer to it.

Public-fork CI hardening

Review `.github/workflows/privacy-bypass.yml` and any cross-repo CI assumptions for public-fork safety. Make the workflow skip or clearly gate private sibling-repo checkouts when `CROSS_REPO_READ_TOKEN` is unavailable, while preserving manual/internal coverage. Keep changes minimal and document how maintainers should run the full privacy-mode test.

Public docs and internal-reference scrub

Scan `README.md`, `docs/`, `site/`, `.github/`, `scripts/`, and tracked config for private Linear URLs, internal roadmap language, and unnecessary `RD-XXXX` references. Do not remove useful technical context. Propose or make low-risk wording changes that make the repo public-friendly, and leave a separate list of references that should stay because they are migrations, tests, or useful historical identifiers.

Binary and container release licensing

Prepare the pre-release compliance plan for official binaries and Docker images. Generate or specify SBOMs for Go, npm, Solidity, submodules, and container base images. Identify LGPL/GPL/MPL/CC obligations, especially go-ethereum and native rapidsnark, and update `THIRD_PARTY_NOTICES.md` with scanner-backed data. Do not publish images or binaries as part of this task.

Prompts To Run In Each Repository

gateway-fm/privacy-proxy

You are in `gateway-fm/privacy-proxy`. Work from the latest main plus the OSS readiness branch context. Finish the minimal source-only Apache-2.0 readiness path without broad source refactors. Verify `LICENSE`, `NOTICE`, `SECURITY.md`, `CONTRIBUTING.md`, `CODE_OF_CONDUCT.md`, `GOVERNANCE.md`, `THIRD_PARTY_NOTICES.md`, `README` license text, npm metadata, Solidity SPDX identifiers, `.gitignore` audit-report hygiene, `.gitmodules` URLs, public-fork CI behavior, `.mcp.json` posture, `RD/internal-reference` posture, and sibling-repo assumptions. Produce a small PR-ready commit stack and a final blocker list limited to items that still require legal or maintainer decisions.

gateway-fm/chain-indexer

You are in `gateway-fm/chain-indexer` on latest main. Audit and prepare the repository for source-only Apache-2.0 publication coordinated with `gateway-fm/privacy-proxy`. Check for missing or conflicting `LICENSE`, `NOTICE`, `SECURITY.md`, `CONTRIBUTING.md`, `CODE_OF_CONDUCT.md`, `GOVERNANCE.md`, `THIRD_PARTY_NOTICES.md`, `README` license text, package/module metadata, generated protobuf provenance, checked-in secrets, private URLs, internal audit files, submodules, CI behavior for public forks, and binary/container release blockers. Make only minimal public-source-readiness edits and produce a concise remaining blocker list. Do not publish binaries or images.

gateway-fm/block-explorer

You are in `gateway-fm/block-explorer` on latest main. Audit and prepare the repository for source-only Apache-2.0 publication coordinated with `gateway-fm/privacy-proxy`. Check `LICENSE`, `NOTICE`, `SECURITY.md`, `CONTRIBUTING.md`, `CODE_OF_CONDUCT.md`, `GOVERNANCE.md`,

THIRD_PARTY_NOTICES.md, README/package metadata, frontend/backend dependency licenses, generated artifacts, environment examples, private service URLs, secrets, internal roadmap references, public-fork CI behavior, and privacy-mode assumptions that depend on chain-indexer or privacy-proxy. Make minimal PR-ready edits and list any blockers for source publication separately from binary/container blockers.

gateway-fm/wallet-emulator-js

You are in gateway-fm/wallet-emulator-js on latest main. Decide whether this repo can be published or referenced publicly as part of the privacy-proxy source-only Apache-2.0 launch. Verify ownership, LICENSE, NOTICE, README license text, package metadata, third-party notices, dependency licenses, generated files, secrets, private URLs, CI, and release artifacts. If it can be public, prepare minimal Apache-compatible readiness commits. If it cannot be public, write the exact privacy-proxy change needed to remove or replace the submodule and any docs/tests that depend on it.

Gateway Repositories In The Apache Plan

| Repository | Source posture

| gateway-fm/privacy-proxy | Publish source under Apache-2.0 after the source-public checklist is complete.

| gateway-fm/chain-indexer | Publish or coordinate under Apache-2.0 before public Privacy Proxy source launch.

| gateway-fm/block-explorer | Publish or coordinate under Apache-2.0 before public Privacy Proxy source launch.

| gateway-fm/wallet-emulator-js | Publish under an Apache-compatible license if retained as a submodule; otherwise remove or replace.

Dependency And License Notes

| Area | Current note

| Apache source with LGPL dependencies | Acceptable for source publication with notice; binary/image distribution needs a compliance plan.

| github.com/ethereum/go-ethereum | Main notable LGPL-3.0 dependency for source users. Upstream command binaries are GPL-3.0; this repo uses library packages.

| github.com/iden3/go-rapidsnark/... | Go wrapper modules are understood to be Apache-2.0/MIT. Native iden3/rapidsnark remains an LGPL-3.0 binary/image review item.

| npm dependencies | Checked lockfiles are mostly MIT, ISC, BSD-family, or Apache-2.0, with MPL/CC/other notice items captured in THIRD_PARTY_NOTICES.md.

Before First Official Binary Or Image Release

| Status | Item

| Open | Generate complete SBOMs for source, binaries, and container images.

| Open | Run Go, npm, Solidity, and container license scans and update THIRD_PARTY_NOTICES.md.

| Open | Resolve go-ethereum LGPL-3.0 binary/container distribution obligations.

| Open | Verify whether iden3 rapidsnark LGPL native code is linked, bundled, or dynamically loaded in release binaries.

| Open | Publish source-to-image mapping for each image tag.

| Open | Sign images/artifacts and publish checksums/provenance.

Source Files

This page summarizes the source-only readiness branch. The canonical working files remain in the repository.

OSS_SOURCE_ONLY_TODO.md THIRD_PARTY_NOTICES.md NOTICE SECURITY.md

Last updated from the local OSS audit branch on July 7, 2026. This page is informational and does not replace legal review.